

CVEs más relevantes de la semana

Del 25/04/2026 al 02/05/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-6987

Descripción: A vulnerability was detected in PicoClaw up to 0.2.4. Impacted is an unknown function of the file /api/gateway/restart of the component Web Launcher Management Plane. Performing a manipulation results in command injection. It is possible to initiate the attack remotely. The project was informed of the problem early through an issue report but has not responded yet.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-04-25



CVE-2026-7036

Descripción: A vulnerability was identified in Tenda i9 1.0.0.5(2204). This vulnerability affects the function R7WebSecurityHandlerfunction of the component HTTP Handler. The manipulation leads to path traversal. Remote exploitation of the attack is possible. The exploit is publicly available and might be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-04-26



CVE-2026-7037

Descripción: A security flaw has been discovered in Totolink A8000RU 7.1cu.643_b20200521. This issue affects the function setVpnPassCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument pptpPassThru results in os command injection. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-26



CVE-2026-7121

Descripción: A flaw has been found in Totolink A8000RU 7.1cu.643_b20200521. This affects the function setWizardCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. This manipulation of the argument wizard causes os command injection. It is possible to initiate the attack remotely. The exploit has been published and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7122

Descripción: A vulnerability has been found in Totolink A8000RU 7.1cu.643_b20200521. This impacts the function setUPnPcfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Such manipulation of the argument enable leads to os command injection. It is possible to launch the attack remotely. The exploit has been disclosed to the public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7123

Descripción: A vulnerability was found in Totolink A8000RU 7.1cu.643_b20200521. Affected is the function setIptvCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Performing a manipulation of the argument setIptvCfg results in os command injection. The attack can be initiated remotely. The exploit has been made public and could be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7124

Descripción: A vulnerability was determined in Totolink A8000RU 7.1cu.643_b20200521. Affected by this vulnerability is the function setIpv6LanCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Executing a manipulation of the argument addrPrefixLen can lead to os command injection. The attack can be launched remotely. The exploit has been publicly disclosed and may be utilized.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7125

Descripción: A vulnerability was identified in Totolink A8000RU 7.1cu.643_b20200521. Affected by this issue is the function setWiFiEasyCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument merge leads to os command injection. The attack may be initiated remotely. The exploit is publicly available and might be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-41462

Descripción: ProjeQtor versions 7.0 through 12.4.3 contain an unauthenticated SQL injection vulnerability in the login functionality where the login variable is directly concatenated into a SQL query without parameterization or sanitization. Attackers can inject arbitrary SQL expressions through the username field at the authentication endpoint to create privileged accounts, read sensitive data, and execute...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7136

Descripción: A weakness has been identified in Totolink A8000RU 7.1cu.643_b20200521. Affected by this issue is the function setDmzCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Executing a manipulation of the argument wanIdx can lead to os command injection. The attack may be launched remotely. The exploit has been made available to the public and could be used for attacks.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7137

Descripción: A security vulnerability has been detected in Totolink A8000RU 7.1cu.643_b20200521. This affects the function setStorageCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument sambaEnabled leads to os command injection. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7138

Descripción: A vulnerability was detected in Totolink A8000RU 7.1cu.643_b20200521. This vulnerability affects the function setNtpCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument tz results in os command injection. The attack can be executed remotely. The exploit is now public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7139

Descripción: A flaw has been found in Totolink A8000RU 7.1cu.643_b20200521. This issue affects the function setWiFiAcIRules of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. This manipulation of the argument mode causes os command injection. The attack is possible to be carried out remotely. The exploit has been published and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7140

Descripción: A vulnerability has been found in Totolink A8000RU 7.1cu.643_b20200521. Impacted is the function CsteSystem of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Such manipulation of the argument HTTP leads to os command injection. The attack may be performed from remote. The exploit has been disclosed to the public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-31255

Descripción: A command injection vulnerability exists in Tenda AC18 V15.03.05.05_multi. The vulnerability is located in the /goform/SetSambaCfg interface, where improper handling of the guestuser parameter allows attackers to execute arbitrary system commands.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7152

Descripción: A vulnerability was identified in Totolink A8000RU 7.1cu.643_b20200521. The affected element is the function setTelnetCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Such manipulation of the argument telnet_enabled leads to os command injection. It is possible to launch the attack remotely. The exploit is publicly available and might be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7153

Descripción: A security flaw has been discovered in Totolink A8000RU 7.1cu.643_b20200521. The impacted element is the function setMiniuiHomeInfoShow of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Performing a manipulation of the argument sys_info results in os command injection. The attack can be initiated remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7154

Descripción: A weakness has been identified in Totolink A8000RU 7.1cu.643_b20200521. This affects the function setAdvancedInfoShow of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Executing a manipulation of the argument tty_server can lead to os command injection. The attack can be launched remotely. The exploit has been made available to the public and could be used for attacks.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7155

Descripción: A security vulnerability has been detected in Totolink A8000RU 7.1cu.643_b20200521. This impacts the function setLoginPasswordCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument admpass leads to os command injection. The attack may be initiated remotely. The exploit has been disclosed publicly and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7156

Descripción: A vulnerability was detected in Totolink A8000RU 7.1cu.643_b20200521. Affected is the function CsteSystem of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument HTTP results in os command injection. The attack may be launched remotely. The exploit is now public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-27



CVE-2026-7202

Descripción: A vulnerability has been found in Totolink A8000RU 7.1cu.643_b20200521. This affects the function setWiFiWpsStart of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument wscDisabled leads to os command injection. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-7203

Descripción: A vulnerability was found in Totolink A8000RU 7.1cu.643_b20200521. This vulnerability affects the function setUrlFilterRules of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument enable results in os command injection. The attack can be launched remotely. The exploit has been made public and could be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-7204

Descripción: A vulnerability was determined in Totolink A8000RU 7.1cu.643_b20200521. This issue affects the function setPptpServerCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. This manipulation of the argument enable causes os command injection. The attack may be initiated remotely. The exploit has been publicly disclosed and may be utilized.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-7240

Descripción: A vulnerability has been found in Totolink A8000RU 7.1cu.643_b20200521. This vulnerability affects the function setVpnAccountCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Such manipulation of the argument User leads to os command injection. The attack can be executed remotely. The exploit has been disclosed to the public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-7241

Descripción: A vulnerability was found in Totolink A8000RU 7.1cu.643_b20200521. This issue affects the function setWiFiBasicCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Performing a manipulation of the argument wifiOff results in os command injection. The attack is possible to be carried out remotely. The exploit has been made public and could be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-7242

Descripción: A vulnerability was determined in Totolink A8000RU 7.1cu.643_b20200521. Impacted is the function setOpenVpnClientCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. Executing a manipulation of the argument enabled can lead to os command injection. The attack may be performed from remote. The exploit has been publicly disclosed and may be utilized.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-7243

Descripción: A vulnerability was identified in Totolink A8000RU 7.1cu.643_b20200521. The affected element is the function setRadvdCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument maxRtrAdvInterval leads to os command injection. It is possible to initiate the attack remotely. The exploit is publicly available and might be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-7244

Descripción: A security flaw has been discovered in Totolink A8000RU 7.1cu.643_b20200521. The impacted element is the function setWiFiEasyGuestCfg of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument merge results in os command injection. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-7248

Descripción: A vulnerability was found in D-Link DI-8100 16.07.26A1. This affects the function tgfile_htm of the file tgfile.htm of the component CGI Endpoint. The manipulation of the argument fn results in buffer overflow. The attack can be executed remotely. The exploit has been made public and could be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-41873

Descripción: **** UNSUPPORTED WHEN ASSIGNED **** Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling') vulnerability in Pony Mail leading to admin account takeover.

This issue affects all versions of the Lua implementation of Pony Mail. There is a Python implementation under development under the name "Pony Mail Foal" that is not affected by this issue, but hasn't been released yet. ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-444

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-41386

Descripción: OpenClaw before 2026.3.22 contains a privilege escalation vulnerability where bootstrap setup codes are not bound to intended device roles and scopes during pairing. Attackers can exploit this during first-use device pairing to escalate privileges beyond their intended role and scope.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-648

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-41397

Descripción: OpenClaw before 2026.3.31 contains a sandbox escape vulnerability allowing attackers to traverse directory boundaries through symlink exploitation during file synchronization operations. Remote attackers can bypass sandbox restrictions by crafting malicious symlinks in mirror sync operations to access arbitrary files outside intended boundaries.

CVSS: 6.8 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-59

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-41446

Descripción: Snap One WattBox 800 and 820 series firmware versions prior to 2.10.0.0 contain undisclosed diagnostic HTTP endpoints that require only the device MAC address and service tag for authentication, both of which are printed in plaintext on the physical device label. Attackers with access to the device label or documentation containing these values can authenticate to the several endpoints and exec...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-04-28



CVE-2026-5166

Descripción: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability in TUBITAK BILGEM Software Technologies Research Institute Pardus Software Center allows Path Traversal.

This issue affects Pardus Software Center: before 1.0.3.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2026-26015

Descripción: DocsGPT is a GPT-powered chat for documentation. From version 0.15.0 to before version 0.16.0, an attacker accessing both the official DocsGPT website or any local and public deployment, can craft a malicious payload bypassing the "MCP test" behavior to achieve arbitrary remote code execution (RCE). This issue has been patched in version 0.16.0.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2026-30893

Descripción: Wazuh is a free and open source platform used for threat prevention, detection, and response. From version 4.4.0 to before version 4.14.4, a path traversal vulnerability in Wazuh's cluster synchronization extraction routine allows an authenticated cluster peer to write arbitrary files outside the intended extraction directory on other cluster nodes. This can be escalated to code execution in th...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:L/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2018-25316

Descripción: Tenda W308R v2 V5.07.48 contains a cookie session weakness vulnerability that allows unauthenticated attackers to modify DNS settings by exploiting insufficient session validation. Attackers can send GET requests to the goform/AdvSetDns endpoint with a crafted admin language cookie to change DNS servers and redirect user traffic to malicious sites.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2018-25317

Descripción: Tenda W3002R/A302/W309R wireless routers version V5.07.64_en contain a cookie session weakness vulnerability that allows unauthenticated attackers to modify DNS settings by exploiting insufficient session validation. Attackers can send GET requests to the /goform/AdvSetDns endpoint with a crafted admin language cookie to change primary and secondary DNS servers, redirecting user traffic to mali...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2018-25318

Descripción: Tenda FH303/A300 firmware V5.07.68_EN contains a session weakness vulnerability that allows unauthenticated attackers to modify DNS settings by exploiting insufficient cookie validation. Attackers can send GET requests to the /goform/AdvSetDns endpoint with a crafted admin cookie to change DNS servers and redirect user traffic to malicious sites.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-04-29



CVE-2022-50993

Descripción: Weaver (Fanwei) E-office versions prior to 10.0_20221201 contain an unauthenticated arbitrary file upload vulnerability in the OfficeServer.php endpoint that allows remote attackers to upload malicious files by sending multipart POST requests with arbitrary filenames and disguised content types. Attackers can upload PHP webshells to the Document directory and execute them via HTTP GET requests ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2025-71284

Descripción: Synway SMG Gateway Management Software contains an OS command injection vulnerability in the RADIUS configuration endpoint at /en/9-2radius.php where the radius_address POST parameter is split and interpolated directly into a sed command without sanitization. An unauthenticated remote attacker can inject arbitrary shell commands by submitting a POST request with crafted radius_address, radius_a...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-35051

Descripción: Traefik is an HTTP reverse proxy and load balancer. Prior to versions 2.11.43, 3.6.14, and 3.7.0-rc.2, there is an authentication bypass vulnerability in Traefik's ForwardAuth middleware when trustForwardHeader=false is configured and Traefik is deployed behind a trusted upstream proxy. This issue has been patched in versions 2.11.43, 3.6.14, and 3.7.0-rc.2.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-39858

Descripción: Traefik is an HTTP reverse proxy and load balancer. Prior to versions 2.11.43, 3.6.14, and 3.7.0-rc.2, there is a high severity authentication bypass vulnerability in Traefik's ForwardAuth and snippet-based authentication middleware. Traefik's forwarded-header sanitization logic targets only canonical header names (e.g., X-Forwarded-Proto) and does not strip or normalize alias variants that use...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-2311

Descripción: IBM i 7.6, 7.5, 7.4, 7.3, and 7.2 s vulnerable to privilege escalation caused by an invalid IBM i Web Administration GUI authorization check. A malicious actor could cause user-controlled code to run with administrator privilege.

CVSS: 6.4 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-40685

Descripción: In Exim before 4.99.2, when JSON lookup is enabled, an out-of-bounds heap write can occur when a JSON operator encounters malformed JSON in an untrusted header, because of an incorrect implementation of \ skipping.

CVSS: 6.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:H

Tipo: CWE-684

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-40687

Descripción: In Exim before 4.99.2, when the SPA authentication driver is used with an adversarial SPA resource, there can be an out-of-bounds write that crashes the connection instance, or erroneous data processing that divulges data from uninitialized heap memory.

CVSS: 4.8 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:L

Tipo: CWE-909

Tecnología: No especificado

Publicado el: 2026-04-30



CVE-2026-7538

Descripción: A vulnerability was identified in Totolink A8000RU 7.1cu.643_b20200521. This issue affects the function Vulnerability of the file /cgi-bin/cstecgi.cgi of the component CGI Handler. The manipulation of the argument proto leads to os command injection. The attack may be initiated remotely. The exploit is publicly available and might be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-7546

Descripción: A security vulnerability has been detected in Totolink NR1800X 9.1.0u.6279_B20210910. The impacted element is the function find_host_ip of the component lighttpd. Such manipulation of the argument Host leads to stack-based buffer overflow. The attack can be executed remotely. The exploit has been disclosed publicly and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-7567

Descripción: The Temporary Login plugin for WordPress is vulnerable to Authentication Bypass in versions up to and including 1.0.0. This is due to improper input validation in the `maybe_login_temporary_user()` function, which fails to verify that the 'temp-login-token' GET parameter is a scalar string before processing it. When the parameter is supplied as an array, PHP's `empty()` check is bypassed and sanit...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-42482

Descripción: A stack-based buffer overflow in `mangle_to_hex_lower()` and `mangle_to_hex_upper()` in `src/rp_cpu.c` in `hashcat v7.1.2` allows an attacker to cause a denial of service or possibly execute arbitrary code via a crafted rule file, or via the `-j` or `-k` rule options used with password candidates of 128 or more characters. The vulnerability is caused by a bounds check that fails to account for the 2x expansion of the rule file.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-42483

Descripción: A heap-based buffer overflow in the Kerberos hash parser in hashcat v7.1.2 allows an attacker to cause a denial of service or possibly execute arbitrary code via a crafted Kerberos hash file. The issue affects module_hash_decode in multiple Kerberos-related modules because account_info_len is calculated from untrusted delimiter positions without upper-bound validation before memcpy copies the d...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-42484

Descripción: A heap-based buffer overflow in hex_to_binary in the PKZIP hash parser in hashcat v7.1.2 allows an attacker to cause a denial of service or possibly execute arbitrary code via a crafted PKZIP hash file. The issue affects modules 17200, 17210, 17220, 17225, and 17230. When data_type_enum<=1, attacker-controlled hex data from a user-supplied hash string is decoded into a fixed-size buffer without...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-05-01



CVE-2026-4882

Descripción: The User Registration Advanced Fields plugin for WordPress is vulnerable to arbitrary file uploads due to missing file type validation in the 'URAF_AJAX::method_upload' function in all versions up to, and including, 1.6.20. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution possible. Note: The vulnera...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-05-02



CVE-2026-7458

Descripción: The User Verification by PickPlugins plugin for WordPress is vulnerable to authentication bypass in all versions up to, and including, 2.0.46. This is due to the use of a loose PHP comparison operator to validate OTP codes in the "user_verification_form_wrap_process_otpLogin" function. This makes it possible for unauthenticated attackers to log in as any user with a verified email address, such...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-05-02



Resumen del Reporte

CVEs analizados: 54

Promedio CVSS: 9.41

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

